

生产就绪与运行韧性标准

从可部署到可运行、可退化、可恢复、可演进的生产准入基线

ESD-OPS-001

v2.0.0-draft.1

DRAFT / NORMATIVE DOMAIN

权威内容来源为 Markdown。本件仅供阅读与评审，未获正式发布批准。

阅读与版本说明

PREVIEW / DRAFT · 非权威阅读视图

本件保留源文档的标题、条款编号、版本与草案状态，不构成新的规范权威。封面、导航、索引与排版标签为生成内容，不能代替正文中的适用范围、条件或批准记录。

制品标识 ESD-OPS-001

版本 2.0.0-draft.1

状态 DRAFT / NORMATIVE DOMAIN

阅读密度 balanced · Visual Profile Candidate，尚未冻结

基准 **commit** 783c7d3b9b6a1e4f715a960c18e687604143f98b

准备标识 353090fade94323347038eee

使用方式 目录与书签可跳转；合订版中的核心文档链接跳转到本件对应篇章。独立版在源字节匹配时提供固定 **commit** 链接，否则指向随附的 **source** 快照。完整输入以准备记录为准，可能包含未提交变更；正文原有编号不重新连续编号。

ESD-OPS-001 v2.0.0-draft.1 DRAFT / NORMATIVE DOMAIN

目录

阅读与版本说明 2

生产就绪与运行韧性标准 5

 1. 适用范围与非目标 6

 2. 核心生产原则 7

 3. 生产服务定义 8

 4. 生产就绪状态模型 10

 5. SLI、SLO 与错误预算 11

 6. 运行模式 13

 7. 故障域与依赖韧性 15

 8. 资源边界、容量与恢复余量 17

 9. 准入、背压与过载 20

 10. 发布策略与 Change Envelope 22

 11. 回滚、前向修复与不可逆变更 24

 12. 数据完整性、备份与恢复 25

 13. RPO、RTO 与灾难恢复 27

 14. 可观测性与诊断 29

 15. Runbook 与操作安全 32

 16. On-call 与运营所有权 33

 17. 安全与运行控制 34

 18. 第三方与供应商韧性 35

 19. 事故响应 36

 20. 韧性验证与演练 38

 21. Production Readiness Review 39

 22. 上线后观察与扩大 40

23. 持续运行评审 41

24. 按风险等级的最低运行要求 42

25. Production Readiness Decision 模板 43

26. Operating Mode Contract 模板 44

27. Dependency Resilience Contract 模板 44

28. Recovery Drill Record 模板 45

29. 最终 Production Readiness Checklist 46

30. 结论 47

生产就绪与运行韧性标准

从可部署到可运行、可退化、可恢复、可演进的生产准入基线

文档属性	内容
文档编号	ESD-OPS-001
版本	2.0.0-draft.1 (基于 1.0.0)
状态	DRAFT / NORMATIVE DOMAIN; 未获发布批准
规范角色	定义生产准入、SLO、运行模式、容量、发布、恢复、值班和持续韧性要求
方法论基础	ESD-METHOD-001 《优秀系统设计与工程保证方法论》
治理基础	ESD-GOV-001 《系统设计与工程保证治理及符合性规范》
证据基础	ESD-ASSURANCE-001 《工程保证论证、证据与裁决规范》
权威格式	本 Markdown 文件; 派生 PDF 或门户页面不构成独立规范

规范目的

本文用于判断一个系统是否不仅“能够上线”，而且能够在真实生产中被观察、控制、退化、恢复、迁移和持续运营。生产就绪不是部署流水线成功，而是当前系统、团队和证据共同具备在声明风险边界内承受正常负载、故障、过载、变更和事故的能力。

摘要

大多数系统在正常路径上都能运行。真正区分生产工程质量的，是系统在以下场景中的行为：

- 依赖变慢
- 流量突增
- 队列积压
- 节点丢失
- 发布失败
- 数据迁移半完成
- 写入成功但响应超时
- 凭据轮换
- 误操作
- 区域故障
- 恢复期间再次故障

本标准将生产就绪定义为一个多维条件，而不是单一 Gate：

Correctness and Safety

- + Operability
- + Bounded Resources
- + Capacity and Recovery Headroom
- + Controlled Change
- + Data Recovery
- + Observability and On-call
- + Evidence-backed Readiness

系统必须有显式的运行模式、服务目标、故障域、依赖契约、资源上界、发布与停止条件、恢复权威、Runbook、Owner 和当前 Evidence。任何关键能力无法证明时，应保持 UNKNOWN；任何无法接受的高后果违反应为 NO_GO。

1. 适用范围与非目标

1.1 适用范围

本标准适用于：

- 新系统首次进入生产；
- 核心系统重大版本、架构或运行环境变更；
- 新区域、新租户、新数据类型或显著流量扩展；
- 数据迁移、Schema 变更、权威状态移动；
- SLO、RPO、RTO、容量或故障域变化；
- 新增外部依赖、特权控制或自动化决策；
- 恢复、重放、灾难恢复和备份体系变更；
- 改变 on-call、Owner、告警或 break-glass 路径；
- 事故后对生产资格的重新评估。

1.2 非目标

本文不：

- 规定所有服务必须达到同样 SLO；
- 要求零故障、零风险或全自动恢复；
- 以监控项数量替代可诊断性；
- 以“有备份”替代恢复演练；
- 以“支持回滚”替代数据和协议层面的可逆性；
- 让 SRE 或平台团队替代系统 Owner 的业务责任；
- 把所有运行复杂度都转移给值班人员。

2. 核心生产原则

OPS-REQ-001：生产完成语义必须明确

系统必须定义什么状态才算业务完成，以及该状态由哪个权威事实表示。进程返回成功、消息 ACK、HTTP 200、对象写入或监控绿色都不能在未定义时自动等同于业务完成。

OPS-REQ-002：运行模式必须显式

生产系统至少应识别适用的运行模式，例如：

```
NORMAL
DEGRADED
READ_ONLY
DRAINING
RECOVERY
QUARANTINE
MAINTENANCE
EMERGENCY
```

每种模式必须定义允许操作、禁止操作、进入/退出条件、Owner 和可观察信号。

OPS-REQ-003：所有资源与积压必须有界

线程、任务、连接、队列、缓存、inflight bytes、重试、临时文件、staging、待补偿工作和隔离积压必须具有可执行的硬上限，以及满载时的准入、背压、拒绝或安全转储行为。仅声明 retention 或“定期清理”不能证明空间有界。

若使用保留窗口推导空间预算，必须同时给出最大入站速率 $\lambda_{\max}$ 、单项最大尺寸 $s_{\max}$ 、保留时间 T 与清理最大延迟 Δ ，再计入元数据、副本、重试副本、在途写入及清理失败积压：

$$B_{\text{required}} \geq \lambda_{\max} \times s_{\max} \times (T + \Delta) + B_{\text{overhead}} + B_{\text{backlog}} + B_{\text{inflight}}$$

这是给定前提下的预算估计，不是自动成立的容量上界。若清理延迟或入站率无法硬约束，必须由容量配额与 admission 在达到硬上限前阻断增长；不得为了清理而删除仍承担提交、对账或恢复责任的数据。

OPS-REQ-004：过载必须显式处置

系统必须选择并实现可观察的准入、背压、降级、负载卸载、拒绝或排队策略。持续过载不得只依赖“自动扩容最终会跟上”。

OPS-REQ-005：恢复能力必须经过验证

备份、Runbook、回滚脚本或多副本只有在代表性故障和目标规模下完成演练，才能作为恢复 Evidence。

OPS-REQ-006：发布是受控实验

重大生产变更必须定义 Change Envelope、前置条件、观察窗口、成功标准、自动停止条件和恢复路径。

OPS-REQ-007：可观测性必须支持行动

每个阻断级告警应能够回答：发生了什么、影响什么、谁负责、下一步做什么。无法指导行动的通知不构成有效运行控制。

OPS-REQ-008：Owner 必须接受 Day-2 责任

在生产准入前，Operational Owner 必须明确接受 SLO、容量、告警、Runbook、on-call、恢复、依赖协调和事故改进责任。

OPS-REQ-009：生产资格必须绑定当前对象

Production Readiness Decision 必须绑定当前 artifact、config、environment、dependency composition 和 Evidence Bundle，不能永久授权未来任意版本。

OPS-REQ-010：运行漂移必须降低确定性

当配置、环境、工作负载、依赖、Owner 或证据超出已验证范围时，生产资格和相关 Claim 必须重新评估；不能继续显示历史 GO 而忽略现实变化。

3. 生产服务定义

3.1 Service Definition

每个生产系统必须拥有最小服务定义：

```
service:
  service_id: "...
  business_capability: "...
  users_or_consumers: []
  business_completion: "...
  authoritative_states: []
  critical_dependencies: []
  critical_properties: []
  supported_operating_modes: []
  risk_tier: "R1|R2|R3"
  technical_owner: "...
  operational_owner: "...
  on_call: "...
  data_classification: "...
  regions_or_failure_domains: []
  lifecycle_status: "...
```

OPS-REQ-011: 服务边界必须以能力和状态定义

服务定义不得只是一组部署名称。必须说明它对谁提供什么业务能力、拥有或依赖哪些权威状态，以及失败如何表现。

3.2 用户旅程和关键路径

SLO、告警和事故优先级应映射到用户或业务关键路径，例如：

```
request accepted
  -> durable command recorded
  -> processing completed
  -> result committed
  -> result visible to consumer
```

基础设施指标必须能关联到该路径，而不是独立存在。

3.3 生产依赖清单

每个关键依赖至少记录：

字段	内容
Dependency	服务、存储、网络、身份、Schema、人员流程等
Owner	依赖责任主体
Contract	成功、错误、超时、容量、版本和支持边界
Criticality	阻断、可降级、可缓存、可绕行
Failure mode	慢、不可用、错误、旧数据、权限拒绝等
Detection	如何识别依赖异常
Fallback	降级、隔离、重试、缓存或停止
Recovery	谁恢复、多久、如何验证

OPS-REQ-012：依赖必须包含非软件主体

DNS、证书、密钥、配置、人员审批、供应商、配额、网络 and 运行手册都可能是关键依赖，不得只列服务调用图。

4. 生产就绪状态模型

4.1 生命周期状态

建议使用：

```
DESIGN
-> PRE_PRODUCTION
-> LIMITED_PRODUCTION
-> GENERAL_PRODUCTION
-> DEPRECATED
-> RETIRED
```

另有横向状态：

```
READINESS_UNKNOWN
READINESS_SUSPENDED
RECOVERY_ONLY
```

4.2 状态含义

状态	含义
PRE_PRODUCTION	尚未承载正式业务结果
LIMITED_PRODUCTION	仅在 Change Envelope 内承载有限范围
GENERAL_PRODUCTION	具备声明范围内的常规生产资格
READINESS_SUSPENDED	因事故、漂移、证据失效或 Owner 缺失暂时失去扩展/发布资格
RECOVERY_ONLY	只允许恢复、对账、排空或必要维修操作
DEPRECATED	禁止新依赖接入，维持退出期运行
RETIRED	生产流量、状态和权限已安全移除

OPS-REQ-013：生产资格可以撤销

GENERAL_PRODUCTION 不是永久属性。重大事故、证据失效、长期 SLO 违约、恢复能力丧失或 Owner 缺失可以将系统降为 READINESS_SUSPENDED。

OPS-REQ-014：扩大暴露必须重新检查资格

从单租户到多租户、单区域到多区域、低流量到大规模、只读到写入或 shadow 到 authoritative output 都属于新的暴露边界，不应被历史资格自动覆盖。

5. SLI、SLO 与错误预算

5.1 SLI 设计

SLI 必须基于用户或业务结果，至少说明：

```
what is measured
numerator / denominator
source of truth
aggregation window
scope
exclusions
late / missing data behavior
measurement delay
owner
```

OPS-REQ-015：SLI 必须测量结果而不只是资源

CPU、内存和 pod availability 是诊断信号，不应单独作为服务可用性 SLI。应优先测量成功完成、正确可见、延迟、完整性或新鲜度。

5.2 SLO Contract

```
slo:
  slo_id: "SLO-..."
  user_journey: "..."
  sli: "..."
  objective: "..."
  window: "..."
  scope: "..."
  exclusions: []
  measurement_source: "..."
  owner: "..."
  error_budget_policy: "..."
  review_trigger: "..."
```

OPS-REQ-016: SLO 与正确性性质不得混写

99.9% 成功率不能允许 0.1% 的资金重复扣款或权限越界。硬 Safety 性质必须独立于统计 SLO。

5.3 错误预算

错误预算策略至少定义：

- 消耗速率；
- 多窗口 burn-rate；
- 何时限制发布；
- 何时转入稳定性工作；
- 哪些错误不允许预算化；
- 异常测量或数据延迟如何处理。

OPS-REQ-017: 错误预算不得覆盖硬属性违反

重复正式结果、数据损坏、越权写入、审计丢失等硬属性违反，即使数量很少，也应按性质处理，而不是纳入普通错误预算。

5.4 新鲜度与积压 SLO

数据和异步系统还应定义：

- end-to-end lag；
- oldest queue age；
- completion freshness；
- replay catch-up time；
- backlog clearance time；

- stale data exposure。

6. 运行模式

6.1 Operating Mode Contract

表 4 · 字段记录视图（列名与原单元格逐项对应）

表 4 · 记录 1 · NORMAL	
Mode	NORMAL
Allowed	正常读写和发布
Forbidden	绕过控制
Entry	所有前置满足
Exit	依赖/资源异常
Signals	SLO、invariant
Authority	Operator

表 4 · 记录 2 · DEGRADED	
Mode	DEGRADED
Allowed	有界降级
Forbidden	未声明语义变化
Entry	依赖或容量下降
Exit	恢复验证
Signals	degradation flag
Authority	Owner

表 4 · 记录 3 · READ_ONLY	
Mode	READ_ONLY
Allowed	查询和恢复
Forbidden	新写入
Entry	写路径不安全
Exit	写路径验证
Signals	write gate
Authority	Authority

表 4 · 记录 4 · DRAINING

Mode	DRAINING
Allowed	完成已接纳工作
Forbidden	新准入
Entry	发布/维护
Exit	inflight=0
Signals	queue/inflight
Authority	Operator

表 4 · 记录 5 · RECOVERY

Mode	RECOVERY
Allowed	replay/reconcile/repair
Forbidden	非必要功能
Entry	故障后
Exit	恢复 Gate
Signals	recovery metrics
Authority	Incident/Owner

表 4 · 记录 6 · QUARANTINE

Mode	QUARANTINE
Allowed	保存异常对象
Forbidden	猜测处理
Entry	输入未知/损坏
Exit	人工或新规则
Signals	quarantine age
Authority	Owner

表 4 · 记录 7 · EMERGENCY

Mode	EMERGENCY
Allowed	最小保命操作
Forbidden	常规变更
Entry	严重事故
Exit	补偿复审
Signals	audit trail
Authority	Break-glass Authority

OPS-REQ-018：模式转换必须有状态机语义

模式切换不能只依赖口头通知。至少应有：

- 可观察状态；
- 进入条件；
- 幂等操作；
- 权限；
- 失败恢复；
- 审计；
- 退出验证。

OPS-REQ-019：降级不得静默改变业务事实

如果降级会返回旧数据、跳过校验、丢弃非关键字段、改变顺序或延迟完成，必须在契约和可观测性中显式表达。

OPS-REQ-020：恢复模式容量必须单独建模

恢复、replay 和 reconciliation 的负载通常不同于正常流量，不能直接使用正常模式容量结论。

7. 故障域与依赖韧性

7.1 Failure Domain

必须识别：

- 进程/容器；
- 节点；
- 机架/可用区；
- 区域；
- 存储分区；
- 网络/路由；
- 身份/密钥；
- 配置/控制面；
- 供应商；
- 人员和权限；
- 共用部署流水线。

OPS-REQ-021：副本必须跨真实故障域

同一节点、同一存储后端、同一凭据、同一配置错误或同一控制面下的多个副本不等于独立容灾。

7.2 Dependency Contract

关键依赖必须定义：

```
timeout
retryability
idempotency
capacity quota
rate limit
error semantics
stale / partial behavior
version compatibility
maintenance communication
recovery escalation
```

OPS-REQ-022：调用超时必须小于上游 deadline

下游 timeout、重试和排队时间必须共享端到端 deadline budget。层层独立超时会导致无意义的尾部延迟和工作放大。

OPS-REQ-023：重试必须有共享预算

重试策略至少包含：

- 可重试错误分类；
- 最大次数或总时间；
- jitter；
- retry budget；
- 幂等条件；
- 过载时抑制；
- 可观察性；
- 失败终态。

无限重试和所有错误统一重试均不符合本标准。

7.3 Circuit Breaker 与隔离

熔断器必须定义：

- 触发指标；
- 窗口；
- 半开探测；

- 失败语义；
- 与重试/扩容的相互作用；
- 恢复和人工覆盖。

隔离策略应考虑 bulkhead、租户配额、优先级和公平性，防止单一热点耗尽全局资源。

8. 资源边界、容量与恢复余量

8.1 Resource Budget

每个关键阶段至少记录：

表 5 · 字段记录视图（列名与原单元格逐项对应）

排版说明：横线表示原表空字段，不表示已有值或已完成填写。

表 5 · 记录 1 · inflight requests/files	
资源	inflight requests/files
单位	count
正常上限	
故障上限	
满载行为	reject/backpressure
Owner	
Signal	

表 5 · 记录 2 · inflight bytes	
资源	inflight bytes
单位	bytes
正常上限	
故障上限	
满载行为	block/admission stop
Owner	
Signal	

表 5 · 记录 3 · queue	
资源	queue
单位	items/bytes
正常上限	
故障上限	
满载行为	shed/defer
Owner	
Signal	

表 5 · 记录 4 · memory working set	
资源	memory working set
单位	bytes
正常上限	
故障上限	
满载行为	stop admission
Owner	
Signal	

表 5 · 记录 5 · connections	
资源	connections
单位	count
正常上限	
故障上限	
满载行为	queue/reject
Owner	
Signal	

表 5 · 记录 6 · retries	
资源	retries
单位	attempts/time
正常上限	
故障上限	
满载行为	fail final
Owner	
Signal	

表 5 · 记录 7 · staging	
资源	staging
单位	bytes/objects
正常上限	
故障上限	
满载行为	cleanup/quarantine
Owner	
Signal	

OPS-REQ-024：容量必须以工作量而不只是请求数建模

如果 item 大小、fan-out、压缩率、模型复杂度或依赖调用差异显著，容量和准入必须使用 bytes、CPU work、cost units 或其他代表工作量的单位。

8.2 Capacity Model

最低模型：

arrival rate
size / work distribution
per-stage service demand
parallelism
stage capacity
queueing delay
headroom
failure-degraded capacity
recovery rate
cost per unit

OPS-REQ-025：峰值和恢复必须分别计算

系统必须回答：

- 正常峰值是否稳定；
- N-1 或依赖降容时是否稳定；
- 故障后积压增长多快；
- 恢复后多久清空；
- 恢复流量是否压垮正常流量；
- 是否需要优先级或限速。

8.3 Headroom

Headroom 用于：

- 突发；
- 自动扩容延迟；
- 节点/区域丢失；
- 发布混合版本；
- replay/recovery；
- 依赖抖动；
- 估算误差。

平均利用率低不等于有恢复余量。

OPS-REQ-026：容量结论必须绑定环境和语料

压测结果必须声明节点规格、运行时、配置、数据分布、依赖行为和版本。环境变化后需要重新确认。

8.4 单位经济性

至少对 R2/R3 或高成本系统计算：

```
$/request  
$/GB processed  
$/tenant  
$/vehicle-hour  
$/replay  
$/recovery-hour
```

OPS-REQ-027：成本控制不得破坏硬性质

成本优化可以调整副本、保留、压缩和批量，但不能静默放宽完整性、安全、恢复和资源边界。

9. 准入、背压与过载

9.1 Admission Control

准入应考虑：

- 当前资源而不是只看实例数；
- 已接纳工作；
- 每租户公平性；
- 请求成本；
- deadline；

- 恢复和高优先级流量；
- 依赖健康；
- Change Envelope。

OPS-REQ-028：先限制入口，再限制内部损害

如果系统在内部队列增长后才发现过载，资源边界通常已经失效。准入应尽可能靠近可控入口，并与端到端 byte/task permits 联动。

9.2 Backpressure

背压链必须说明：

```
where pressure is detected
how it propagates
where work waits
maximum wait
what is rejected or shed
how upstream reacts
how operators observe it
```

OPS-REQ-029：队列满载行为必须确定

每个队列满载时只能执行预定义行为，例如：

- 阻塞；
- 拒绝；
- 降级；
- 丢弃允许丢弃的低优先级工作；
- 延迟准入；
- 隔离到受控存储。

不得退化为无界分配或无限重试。

9.3 Load Shedding

负载卸载必须明确：

- 哪些工作可丢弃；
- 对用户的可见语义；
- 公平性；
- 重试建议；
- 审计；
- 恢复后是否补偿。

OPS-REQ-030：不得随机丢弃关键业务事实

如果工作代表不可丢失命令、资金或审计事实，过载时应拒绝准入或持久化到有界权威队列，而不是静默丢弃。

9.4 控制回路

自动扩容、重试、限流、熔断、队列消费者和数据库连接池共同形成控制系统。必须评审：

- 采样延迟；
- 控制延迟；
- 过度响应；
- 振荡；
- 多回路相互放大；
- 冷启动；
- 配额硬限制。

10. 发布策略与 Change Envelope

10.1 发布前置

重大生产发布至少需要：

- 当前制品和配置身份；
- Production Readiness Decision；
- Release Evidence Bundle；
- Change Envelope；
- 版本兼容和迁移状态；
- 回滚或 forward-recovery 路径；
- Owner 和观察人员；
- 变更窗口与依赖协调；
- 自动停止条件。

OPS-REQ-031：发布流程必须支持停止

发布系统必须能够：

- 暂停新扩展；
- 停止准入；
- 回滚可逆制品；
- 转入安全模式；
- 保留证据；

- 触发人工升级。

只能“继续直到完成”的流水线不适合高风险变更。

10.2 Change Envelope

```
change_envelope:
  change_id: "...
  subject_identity: "...
  semantic_delta: "...
  population: "...
  max_traffic_or_data: "...
  max_duration: "...
  max_regions_or_tenants: "...
  preconditions: []
  success_criteria: []
  observation_window: "...
  abort_conditions: []
  rollback_or_forward_recovery: "...
  owner: "...
  release_authority: "...
```

OPS-REQ-032: Change Envelope 必须与 Evidence 范围一致

如果只验证了某类对象、某区域或某规模，首次暴露不得超出该范围。

10.3 Canary、Shadow 与 Dark Launch

Canary

用于有限权威流量，必须有正确性、资源、安全和 SLO 停止条件。

Shadow

可验证处理逻辑和容量，但不应产生权威副作用。必须防止影子路径意外写入或污染指标。

Dark Launch

可以提前部署依赖和资源，但未承载业务结果。不能替代真实流量下的语义验证。

OPS-REQ-033: Canary 不能只观察错误率

应至少观察：

- hard property violations;
- duplicate/conflict;

- lineage/provenance;
- queue age;
- memory/resource bounds;
- retry amplification;
- dependency impact;
- user outcome;
- unit cost。

10.4 Freeze 与高风险窗口

在依赖团队不可用、无恢复能力、重大业务高峰或证据过期时，应限制高风险发布。Freeze 应基于风险，不应成为长期替代工程能力的固定仪式。

11. 回滚、前向修复与不可逆变更

11.1 回滚类型

类型	内容
Binary rollback	恢复旧二进制
Configuration rollback	恢复旧配置/策略
Traffic rollback	将流量移回旧路径
Data rollback	恢复旧数据状态，通常最危险
Protocol rollback	回到旧协议/Schema
Forward recovery	保留新状态，通过修复继续前进

OPS-REQ-034：必须区分代码可回滚与系统可回滚

旧二进制可以部署，不代表它能读取新 Schema、理解新状态或撤销已经产生的外部副作用。

11.2 不可逆变更

以下通常属于难逆转：

- 删除或重编码权威数据；
- 改变稳定身份；
- 外部消费者不可控的契约；
- 不可补偿副作用；
- 权限和密钥泄露；
- 跨区域数据移动；
- irreversible encryption/key changes。

OPS-REQ-035：不可逆变更必须采用分阶段协议

常见模式：

```
expand
-> dual-read / compatible write
-> migrate
-> verify / reconcile
-> switch authority
-> observe
-> contract
```

不得在同一不可回退步骤中同时改变数据、代码、权限和权威边界。

11.3 Forward Recovery

当回滚不安全时，必须预先定义：

- 如何停止进一步损害；
- 如何识别已受影响对象；
- 如何补偿或修复；
- 如何验证收敛；
- 如何向用户和依赖方表达状态；
- 谁拥有最终完成判断。

12. 数据完整性、备份与恢复

12.1 数据分类

至少区分：

- 权威状态；
- 派生状态；
- 可重建缓存；
- 审计/证据；
- 临时 staging；
- 隔离数据；
- 用户可见结果。

恢复策略必须根据状态类型确定。

OPS-REQ-036：恢复必须从权威状态开始

不得将缓存、过期副本或临时文件当作恢复权威，除非系统契约明确它们拥有最终裁决权。

12.2 Backup Contract

```
backup:
  data_scope: "...
  authority_source: "...
  frequency: "...
  retention: "...
  encryption: "...
  immutability: "...
  cross_failure_domain: "...
  integrity_check: "...
  owner: "...
```

OPS-REQ-037：有备份不等于可恢复

必须验证：

- 备份可读取；
- 密钥和权限可用；
- 依赖版本可重建；
- 恢复顺序正确；
- 恢复后的数据完整性可校验；
- RTO/RPO 可达到；
- 恢复不会覆盖新的正确数据。

12.3 Restore Drill

演练至少记录：

```
scope
backup identity
restore target
time to detect
time to start
time to restore
time to validate
data loss / divergence
manual steps
failed steps
follow-up actions
```

OPS-REQ-038：恢复验证必须有业务 Oracle

“数据库启动成功”不代表业务恢复完成。必须验证关键实体、约束、lineage、计数、对账和用户可见结果。

12.4 Replay

Replay 必须定义：

- 原始输入是否不可变；
- pipeline/config/model/schema 版本；
- 重放身份；
- 副作用隔离；
- 重复和冲突；
- 容量与优先级；
- 结果对账；
- 旧结果替换/并存语义。

OPS-REQ-039：Replay 不得与实时流量争夺无界资源

必须有速率、配额、独立队列或优先级，保证恢复不会使生产再次失稳。

12.5 Reconciliation

对跨系统或非原子边界，应提供：

- 可枚举业务身份；
- 权威比较；
- 差异分类；
- 幂等修复；
- 审计；
- 完成标准。

13. RPO、RTO 与灾难恢复

13.1 定义

- RPO：允许丢失或需要重新生成的最大业务时间范围；
- RTO：本套系统一以目标业务能力实际中断时刻为起点，到通过业务 Oracle 确认恢复为终点的目标时间上限；不得按检测时刻重新起算；
- MTPD：业务可承受的最大中断时间；
- Recovery Capacity：恢复期间处理正常流量和积压的能力。

每次演练/事故至少记录以下时间点，使用一致时钟或注明时钟误差：

时间点	含义
t0	目标业务能力开始中断
t_detected	被监测或人员发现
t_decided	决定启动恢复
t_restored	技术组件恢复可服务
t_validated	业务 Oracle 确认目标能力与数据状态恢复

实际恢复历时为 $t_{\text{validated}} - t_0$ ，与 RTO 比较；检测耗时、决策耗时、技术恢复耗时和验证耗时分开保留。若 t_0 不可精确确定，应报告最早/最晚可能时刻及恢复历时区间，以保守上界评估；无可靠边界时保持 UNKNOWN。可以另报“检测后恢复耗时”，但不得用该较短指标宣称满足以业务中断为起点的 RTO。

OPS-REQ-040：RPO/RTO 必须从业务后果推导

不能只使用云服务默认值。目标必须与数据语义、客户承诺、法律和恢复成本一致。

13.2 DR Scope

DR 计划必须覆盖：

- 故障场景；
- 受影响状态和依赖；
- 权威切换；
- DNS/身份/凭据；
- 数据一致性；
- 人员和沟通；
- 恢复验证；
- 回切；
- 事后对账。

OPS-REQ-041：多区域不自动等于 DR

如果区域共享控制面、密钥、身份、部署、错误配置或同步损坏，多区域可能复制故障而不是隔离故障。

13.3 演练等级

等级	内容
Tabletop	角色和决策路径演练
Component Restore	单组件恢复
Partial Failover	有限流量/租户切换
Full Technical Failover	整体技术切换，可能非权威
Business DR Exercise	业务、数据、沟通和回切全链路

OPS-REQ-042：R2/R3 必须周期演练

周期由风险、变化速度和业务要求决定。架构或依赖重大变化后，不应等待固定年度周期才重新验证。

14. 可观测性与诊断

14.1 四类信号

用户/业务结果

- completion success;
- correctness/conflict;
- latency/freshness;
- data completeness;
- business rejection。

系统状态

- queue depth/age;
- inflight;
- state transition;
- operating mode;
- dependency status;
- version composition。

资源

- CPU、memory、disk、network;
- connection pool;
- byte permits;

- retry budget;
- staging/quarantine。

保证与安全

- invariant violation;
- provenance mismatch;
- evidence/assumption drift;
- authz denial;
- break-glass;
- audit continuity。

OPS-REQ-043：可观测性必须从设计模型生成

指标和日志应映射到关键性质、状态机、队列、依赖、运行模式和恢复步骤。上线后随意添加资源图不能替代系统模型。

14.2 关联身份

日志、trace、结果和审计应使用稳定业务身份关联：

```
request / operation ID
source identity
result identity
pipeline/version
config/schema/model version
tenant/region
release ID
```

OPS-REQ-044：高基数必须受控

稳定身份不意味着把所有 ID 直接写入指标标签。应根据查询模式在 logs/traces/audit 中保存，指标使用聚合或受控维度。

14.3 Alert Contract

```
alert:
  alert_id: "ALERT-..."
  symptom_or_property: "..."
  threshold_or_rule: "..."
  severity: "..."
  user_impact: "..."
  owner: "..."
  first_actions: []
  runbook: "..."
  escalation: "..."
  auto_mitigation: "..."
  false_positive_review: "..."
```

OPS-REQ-045: 告警必须具备可执行响应

没有 Owner、Runbook 或明确行动的告警应被删除、降级为仪表盘信号或补齐控制，而不是长期制造噪声。

14.4 Dashboard

至少应能回答：

1. 用户是否受到影响？
2. 哪个运行模式和版本正在运行？
3. 压力积累在哪里？
4. 哪个依赖或故障域异常？
5. 恢复是否前进？
6. 是否存在 hard property violation？
7. 是否超出已验证范围？

15. Runbook 与操作安全

15.1 Runbook 最低内容

```
purpose and scope
preconditions
required authority
risk and blast radius
exact steps
verification after each step
abort conditions
rollback / forward recovery
evidence to retain
escalation
last exercised date
owner
```

OPS-REQ-046: Runbook 必须可执行且经过演练

只描述原则、包含过期命令或依赖作者记忆的 Runbook 不构成生产能力。

15.2 操作分级

类型	要求
Safe read-only diagnostic	广泛可用，最小权限
Routine mutation	自动化、幂等、审计、受限范围
High-risk mutation	双人/审批、预检查、Change Envelope
Emergency mutation	break-glass、最小期限、全量审计

OPS-REQ-047: 高风险操作应优先自动化为受控命令

不得要求值班人员在事故压力下手工拼接复杂数据库、Kubernetes 或云控制命令。自动化应提供预检查、范围限制、dry-run、审计和结果验证。

15.3 Drain 与 Shutdown

系统必须定义：

- 停止新准入；
- 等待或转移 inflight；
- checkpoint/commit；
- 超时后处理；

- 可观察完成；
- 被强制终止后的恢复。

OPS-REQ-048：优雅关闭不得依赖无限等待

必须有明确 deadline 和未完成工作的持久化/重投递/终态语义。

16. On-call 与运营所有权

16.1 On-call Readiness

生产准入前必须确认：

- 值班覆盖；
- 联系和升级路径；
- 权限；
- Runbook；
- 仪表盘；
- 依赖联系人；
- 事故角色；
- 新系统培训；
- 交接；
- 常见故障演练。

OPS-REQ-049：无 Operational Owner 不得进入核心生产

如果没有团队愿意承担告警、恢复和事故责任，系统还不是可运营产品。

16.2 值班负担

应观测：

- page 数量；
- 非行动告警比例；
- 夜间唤醒；
- 重复事件；
- 手工修复频率；
- 权限和工具缺口；
- 事故后待办关闭率。

OPS-REQ-050：长期人工补偿必须进入工程计划

持续依赖值班人员手工清理、重放、扩容或修复，说明系统存在结构性运行债务，不能被视为稳定状态。

17. 安全与运行控制

17.1 最小权限

生产身份应按：

- 角色；
- 环境；
- 租户；
- 操作；
- 时间；
- 资源范围；

进行限制。

OPS-REQ-051：读、写、管理和 break-glass 权限必须分离

拥有观测权限不应自动获得状态修改权限；自动化发布身份不应拥有无限人工控制权限。

17.2 Secret 与证书

必须定义：

- 来源；
- 轮换；
- 过期监测；
- 撤销；
- 备份/恢复；
- 使用范围；
- 审计；
- 紧急替换。

OPS-REQ-052：凭据轮换必须演练

未验证的轮换可能导致全局故障。关键证书、密钥和 token 的轮换应在到期前完成受控演练。

17.3 Audit

审计应覆盖：

- 特权操作；
- 权限变化；
- 生产发布；
- Exception 与 break-glass；
- 数据修复；
- 证据和门禁变更；
- 权威切换；
- 恢复和回放。

OPS-REQ-053：审计链中断必须可检测

审计缺失不能被视为“没有操作发生”。对高风险主体，审计不可用应限制变更或触发降级。

18. 第三方与供应商韧性

18.1 依赖评估

关键第三方必须评估：

- SLA/SLO 与实际表现；
- 速率、配额和突发；
- 数据导出和迁移；
- 版本/弃用通知；
- 安全与合规；
- 支持和升级路径；
- 区域和故障域；
- 单点依赖；
- 退出成本。

OPS-REQ-054：外部 SLA 不自动满足内部 SLO

必须考虑调用链、重试、配额、共享故障和测量口径差异。

18.2 供应商故障

应预定义：

- 缓存或降级；
- 用户可见语义；

- 暂停写入；
- 替代路径；
- 数据对账；
- 合同升级；
- 恢复后补偿。

OPS-REQ-055：关键供应商退出必须有可行路径

不一定需要随时双活，但必须知道数据如何导出、契约如何迁移、身份如何重建、最长退出时间和主要阻断。

19. 事故响应

19.1 Incident Lifecycle

Detect

- > Triage
- > Stabilize
- > Contain
- > Recover
- > Validate
- > Communicate
- > Learn
- > Assurance Delta

OPS-REQ-056：先稳定再追因

事故期间应优先限制损害、保护证据和恢复关键能力，避免在不安全状态下进行高风险根因实验。

19.2 角色

至少定义：

- Incident Commander；
- Operations Lead；
- Communications Lead；
- Subject Matter Expert；
- Scribe；
- Security/Compliance Liaison（如适用）。

OPS-REQ-057：事故指挥权必须明确

多人并发修改同一生产状态会扩大事故。Incident Commander 应控制优先级和高风险操作授权。

19.3 恢复完成

事故“恢复”必须至少验证：

- 用户结果恢复；
- 数据完整性；
- 积压收敛；
- 依赖稳定；
- 临时权限撤销；
- 运行模式回归；
- 证据保留；
- 未知和残余风险记录。

OPS-REQ-058：恢复后必须防止自动重新进入故障

重新打开流量、重试或自动扩容前，必须验证根因控制和容量边界，避免恢复动作触发第二次故障。

19.4 事故复盘

复盘应关注：

- 为什么系统允许损害发生；
- 检测为何及时或迟延；
- 哪些 Assumption 错误；
- 哪些控制、Evidence 和 Runbook 缺失；
- 组织和权限如何影响响应；
- Assurance Delta。

20. 韧性验证与演练

20.1 验证层级

层级	示例
Component	crash、timeout、disk full、dependency errors
Integration	broker/store/identity 边界故障
System	端到端过载、混合版本、恢复
Operational	Runbook、on-call、权限、沟通
Disaster	区域/控制面/凭据/数据恢复

OPS-REQ-059：演练必须有安全边界

每次演练应定义：

- 假设；
- 最大爆炸半径；
- 禁止动作；
- 观察指标；
- 停止条件；
- 恢复路径；
- 责任人；
- Evidence。

20.2 Game Day

Game Day 不应只验证技术故障，还应覆盖：

- 告警是否到达；
- 值班是否有权限；
- Runbook 是否准确；
- 依赖是否可协调；
- 业务是否理解降级；
- 沟通是否及时；
- 恢复是否可验证。

OPS-REQ-060：演练发现必须闭环

发现的问题应进入：

- Critical Property；
- Capacity/Failure Model；
- Runbook；
- Alert；
- Automation；
- Evidence；
- Assurance Delta；
- Owner 与期限。

21. Production Readiness Review

21.1 输入

R2/R3 Review 至少需要：

- Service Definition；
- 风险等级；
- Design/Architecture Decision；
- Critical Property 和状态模型；
- SLO/RPO/RTO；
- 依赖与故障域；
- Resource/Capacity Model；
- Operating Modes；
- Release/Recovery Plan；
- Observability/Runbook/On-call；
- Threat Model；
- Assurance Review；
- Release Evidence Bundle；
- Exception Register；
- Change Envelope。

21.2 阻断条件

以下情况默认 NO_GO 或 UNKNOWN：

- 业务完成和权威状态不清；
- 关键资源无上界；

- 高后果副作用的提交/ACK/恢复语义不清；
- 无 Operational Owner 或 on-call；
- 关键 SLO 无测量来源；
- 数据恢复未验证；
- 不可逆变更无前向修复；
- 发布无法停止或限制暴露；
- 阻断级 Evidence 失效或错绑；
- 关键 Exception 无期限或补偿控制；
- break-glass 无审计；
- 运行漂移无法检测。

OPS-REQ-061: Readiness Review 必须区分设计缺口与发布缺口

设计语义缺失通常不能通过临时运行条件补偿；发布环境、容量或证据缺口可以在严格条件下 CONDITIONAL_GO。

21.3 决策

Production Readiness Decision 使用 ESD-GOV-001 的状态，并必须说明：

```
scope
subject identity
risk tier
supported claims
blocking unknowns
exceptions
residual risks
change envelope
release authority
validity / review trigger
```

OPS-REQ-062: GO 只对声明范围有效

有限租户、单区域或某规模的 GO 不得被解释为全局通用生产资格。

22. 上线后观察与扩大

22.1 Observation Window

上线后观察至少覆盖：

- 正常流量；
- 一个有意义的峰值或业务周期；
- 队列和资源稳定；

- 错误预算；
- hard property；
- 依赖影响；
- 单位成本；
- 支持和 on-call 负担。

OPS-REQ-063：扩大必须基于成功标准而非时间自动发生

Canary 运行满固定小时不代表成功。必须满足预定义正确性、资源、恢复和用户结果条件。

22.2 Closure

Limited Production 结束时必须作出：

```
EXPAND  
HOLD  
ROLL_BACK  
FORWARD_REPAIR  
SUSPEND_READINESS
```

并保存 Evidence 和理由。

23. 持续运行评审

23.1 触发器

以下事件触发 Readiness 复审：

- SLO 长期违约；
- 重大事故或数据修复；
- 容量或工作负载越界；
- 依赖、区域、Owner 或 on-call 变化；
- 证据失效；
- 关键 Exception 到期；
- 新不可逆状态或权限；
- 长期手工补偿；
- 恢复演练失败；
- 至少每 12 个月一次。

OPS-REQ-064：运行债务必须可见

长期告警噪声、手工修复、容量不足、过期 Runbook、未关闭 Exception 和未演练恢复都应进入 Operating Risk Register，而不是被日常操作吸收。

23.2 Retirement Readiness

系统退出也必须设计：

- 停止新依赖；
- 数据保留/删除；
- 消费者迁移；
- 权限撤销；
- 证据保留；
- 域名、证书、队列、存储和账单清理；
- 最终审计；
- Owner 解除。

OPS-REQ-065：废弃不等于无人维护

在所有状态、流量、权限和依赖安全退出前，系统仍需 Operational Owner 和最低运行能力。

24. 按风险等级的最低运行要求

能力	R0	R1	R2	R3
退出/删除条件	必须	必须	必须	必须
业务完成语义	关键项	必须	必须	必须
SLI/SLO	可选	基础	完整	完整 + 独立审查
Operational Owner	可选	必须	必须	必须
运行模式	最小	核心	完整	完整 + 权限控制
Resource Bounds	硬上限	必须	完整	完整 + 故障降容
On-call	不适用	按需	必须	必须 + 演练
Recovery Drill	可选	核心恢复	必须	周期性完整演练
Change Envelope	首次暴露	重大变更	必须	必须 + 自动停止
DR	不适用	按业务	必须评估	必须验证
Evidence Bundle	最小	基础	完整	完整 + 独立评价
Incident Assurance Delta	可选	重大事故	必须	必须

25. Production Readiness Decision 模板

```
# Production Readiness Decision

- Decision ID:
- System / Change:
- Risk tier:
- Subject identity:
- Current lifecycle state:
- Requested lifecycle state:
- Review date:
- Release Authority:

## 1. Business capability and completion semantics

## 2. Critical properties and authoritative states

## 3. SLI / SLO / RPO / RTO

## 4. Dependencies and failure domains

## 5. Operating modes

## 6. Resource bounds, capacity and recovery headroom

## 7. Overload, backpressure and retry policy

## 8. Release, migration and recovery strategy

## 9. Data integrity, backup, restore and reconciliation

## 10. Observability, alerting, runbooks and on-call

## 11. Security and privileged operations

## 12. Assurance Review and Evidence Bundle

## 13. Exceptions, unknowns and residual risks

## 14. Change Envelope

## 15. Decision
```

字面文本 · continued

```
GO / CONDITIONAL_GO / NO_GO / UNKNOWN

## 16. Conditions and deadlines

## 17. Review and invalidation triggers
```

26. Operating Mode Contract 模板

空表模板 · 26. Operating Mode Contract 模板

Mode	
Purpose	
Allowed	
Forbidden	
Entry Criteria	
Exit Criteria	
Signals	
Authority	
Runbook	

27. Dependency Resilience Contract 模板

```
dependency:
  dependency_id: "DEP-..."
  name: "..."
  owner: "..."
  contract:
    availability: "..."
    latency: "..."
    timeout: "..."
    capacity_quota: "..."
    retryable_errors: []
    idempotency: "..."
    version_compatibility: "..."
  criticality: "BLOCKING|DEGRADABLE|OPTIONAL"
```

字面文本 · continued

```
failure_modes: []
detection: []
fallback: "...
escalation: "...
recovery_validation: "...
review_trigger: "...
```

28. Recovery Drill Record 模板

```
# Recovery Drill DRILL-XXX

- System:
- Scenario:
- Risk tier:
- Date:
- Participants:
- Source state / backup identity:
- Target environment:

## Objectives

## Preconditions and safety boundary

## Expected RPO / RTO

## Timeline

## Actions

## Business validation

## Actual RPO / RTO

## Failed or manual steps

## Evidence

## Residual risks

## Required changes

## Assurance Delta
```

29. 最终 Production Readiness Checklist

业务与语义

- ☐ 服务能力、用户和业务完成语义明确；
- ☐ 权威状态、稳定身份和关键性质明确；
- ☐ 风险等级和失败后果有依据；
- ☐ 设计批准和发布批准已区分。

目标与运行模式

- ☐ SLI 基于用户/业务结果；
- ☐ SLO、RPO、RTO 和测量来源明确；
- ☐ hard property 未被错误预算化；
- ☐ NORMAL、DEGRADED、RECOVERY 等模式有契约；
- ☐ 模式切换、权限和退出验证可执行。

故障与资源

- ☐ 关键依赖和真实故障域已建模；
- ☐ timeout、retry budget、熔断和背压闭合；
- ☐ 所有可增长资源有上界；
- ☐ 峰值、N-1、积压和恢复容量经过计算；
- ☐ 单位经济性处于可接受范围。

发布与迁移

- ☐ Change Envelope 与 Evidence 范围一致；
- ☐ 发布可以暂停和停止；
- ☐ Canary 包含正确性和资源停止条件；
- ☐ mixed-version 行为经过验证；
- ☐ 回滚、前向修复和不可逆步骤明确；
- ☐ 迁移具有 expand/migrate/verify/contract 纪律。

数据与恢复

- ☐ 权威、派生、缓存和 staging 已分类；
- ☐ 备份完整性和密钥可用性已验证；
- ☐ Restore/Replay/Reconciliation 有业务 Oracle；
- ☐ RPO/RTO 在代表性演练中得到支持；
- ☐ 恢复流量不会使系统再次失稳；
- ☐ DR 计划覆盖控制面、身份、数据和人员。

可观测性与运营

- ☐ 用户结果、状态、资源、依赖和保证信号可观察；
- ☐ stable IDs 支持端到端关联；
- ☐ 告警有 Owner、Runbook 和行动；
- ☐ Runbook 经过演练且命令仍有效；
- ☐ on-call、权限、升级和依赖联系人明确；
- ☐ 高风险操作自动化、受限、审计。

安全与事故

- ☐ 读、写、管理和 break-glass 权限分离；
- ☐ secret/证书轮换和撤销经过验证；
- ☐ 审计链完整且中断可检测；
- ☐ 事故角色、通信和证据保留明确；
- ☐ 重大事故会产生 Assurance Delta。

证据与裁决

- ☐ Assurance Review 达到 Decision-grade；
- ☐ Release Evidence Bundle 绑定当前对象；
- ☐ 阻断级 Evidence 为 CURRENT；
- ☐ Exception 有范围、期限和补偿控制；
- ☐ 高后果 UNKNOWN 未被静默放行；
- ☐ GO 的范围、有效期和失效触发明确。

30. 结论

生产就绪不是“代码已合并、镜像已构建、部署已成功”。它是一项持续的系统能力：团队知道什么是业务完成，系统知道自己处于什么模式，资源和故障不会无界扩散，发布可以被限制和停止，数据可以从权威事实恢复，值班人员有权限和 Runbook，关键主张有当前 Evidence，环境漂移会使过期结论失效。

最终闭环为：

```
Design semantics
-> Production controls
-> Readiness evidence
-> Limited exposure
-> Runtime observation
-> Recovery and incident learning
-> Revalidated readiness
```

当系统能够在正常、过载、降级、恢复和演进中保持这些能力时，它才真正从“可以部署的软件”成为“可以长期负责的生产系统”。